

Ataki Evil Twin, KARMA i MANA
Analiza, detekcja i przeciwdziałanie

Bezpieczeństwo Sieci Bezprzewodowych
AGH WIEiT | 2026

Agenda

Ataki

Czym jest Rogue AP?

Evil Twin — klonowanie SSID

KARMA — pasywne przechwytywanie

MANA — zaawansowany atak

Detekcja

Metoda 1: Fingerprinting IE

Metoda 2: Analiza RSSI

Metoda 3: Sequence Numbers

Eksperyment

10 cykli ON/OFF — wyniki

Evil Twin vs KARMA — porównanie

WiFiSlayer — narzędzie zewnętrzne

Wnioski

Mitygacja i ochrona

Podsumowanie

Czym jest Rogue Access Point?

Nieautoryzowany punkt dostępowy podszywający się pod legalną sieć WiFi.

Standard **802.11 nie weryfikuje tożsamości AP**. Klient nie widzi różnicy między oryginalnym AP a atakującym.

Zagrożenia:

Kradzież haseł (captive portal)

Przechwycenie ruchu (MITM)

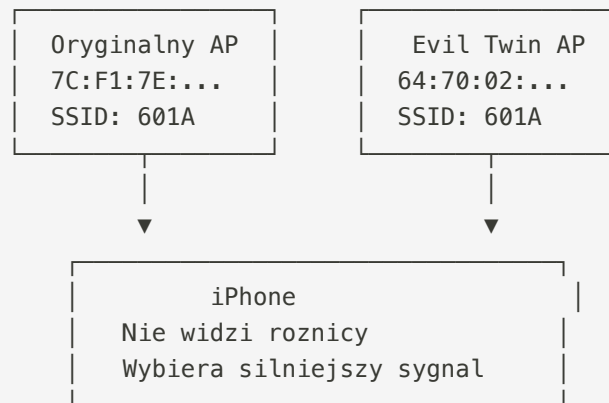
Kradzież poświadczonych EAP

Nasze środowisko:

Kali Linux VM + 2 karty TP-Link RT5572

Oryginalny AP: SSID **601A** (BSSID: 7C:F1:7E:C1:7B:95)

Ofiara: **iPhone** (BA:A1:0E:08:E0:35)



An error occurred on this slide. Check the terminal for more information.

Atak 2: KARMA

KARMA = **K**arma **A**ttacks **R**adio **M**achines **A**utomatically

Jak działa:

Rogue AP **nasluchuje** probe requestow

Kazdy klient wysyla zapytania o znane sieci

KARMA **odpowiada beaconem** z zadany SSID

Klient widzi "swoja" siec i moze sie polaczyc

Roznica od Evil Twin:

Cecha	Evil Twin	KARMA
Deauth	TAK	NIE
Zna SSID?	TAK	NIE
BSSID:SSID Wiele : 1		1 : wiele

Wykrywanie Duplikat SSID 1 BSSID → wiele SSID

Nasze wyniki:

KARMA AP (hostapd-mana, enable_mana=0):

BSSID **64:70:02:18:B9:22** przechwycil probe requesty iPhone'a:

```
Probe Request: SSID=601A, RSSI=-34 dBm
```

```
Probe Request: SSID=FreeWiFi, RSSI=-34 dBm
```

Kluczowa anomalia:

Jeden BSSID nadaje 2 rozne SSID (601A + FreeWiFi). Normalny AP nadaje tylko svoj SSID.

Detection signature:

1 BSSID → wiele SSID (RSSI stale = jedno urzadzenie)

Atak 3: MANA

MANA Toolkit (SensePost, Defcon 22) — ewolucja KARMY.

Ulepszenia:

Odpowiada na **directed probe requests** (ignoruje docelowy BSSID)

Loud Mode — emituje popularne SSID co ~10s

EAP Capture — przechwytyje handshake Enterprise

Multiple BSSID — jeden interfejs, wiele wirtualnych AP

Nasze wyniki:

MANA AP (hostapd-mana, enable_mana=1) przechwycił **directed probe requesty** iPhone'a:

```
MANA - Directed probe request
      for SSID '601A'
      from ba:a1:0e:08:e0:35
```

Status eksperymentu:

Element	Wynik
MANA AP uruchomiony	TAK
Directed probe przechwycony	TAK
Captive Portal iOS	NIE — Apple CNA zablokował
Pelen atak MANA	NIE — ograniczenia sprzętowe

MANA to atak **pasywny** — nie wymusza rozłączenia.

Czeka aż klient sam przejdzie do naszego AP.

Evil Twin używa deauth do siłowego przełączenia.

KARMA odpowiada na probe requesty bez deauth.

An error occurred on this slide. Check the terminal for more information.

An error occurred on this slide. Check the terminal for more information.

An error occurred on this slide. Check the terminal for more information.

Eksperyment: 10 cykli ON/OFF Evil Twin

Przebieg:

iPhone połączony z **Evil Twin** (64:70:02:18:B9:22)

Wylaczenie AP (`kill hostapd`) — iPhone traci Wi-Fi na ~5s

Wlaczenie AP (`create_ap`) — iPhone reconnectuje w ~6s

Powtorzono **10 razy**

Statystyki:

Metryka	Wartosc
Pakiety	55 490
Beacony Evil Twin	2 928
Beacony Oryginal	3 882
Sukces reconnectu	10/10 (100%)
Sredni czas reconnectu	~6s

Co udowodnilismy:

iPhone **przechodzi** miedzy AP bez interwencji uzytkownika

Czas reconnectu ~6s — **niezauwazalny** dla ofiary

Sequence Numbers jednoznacznie potwierdzaja **2 urzadzenia**

Kazde przelaczenie zostalo zarejestrowane w pcap

Wykres Seq Numbers z 10 cykli znajduje sie na poprzednim slajdzie.

Porównanie: Evil Twin vs KARMA

Evil Twin

Wiele BSSID → 1 SSID

Celuje w **konkretna** siec

Używa **deauth** (silowe rozłączenie)

Wykrywalny przez **duplikat SSID**

Potrzebuje **znac SSID** ofiary

Nasze dane:

2 BSSID z SSID "601A"

RSSI: -22.8 vs -42.1 (delta 20.3 dBm)

Różne Vendor OUI

KARMA

1 BSSID → wiele SSID

Lapie **wszystkie** probe requesty

Bez deauth (pasywny)

Wykrywalny przez **anomalie SSID**

Nie musi znac SSID ofiary

Nasze dane:

1 BSSID z 2 różnymi SSID (601A + FreeWiFi)

RSSI: stale (to samo urządzenie)

Przechwycone probe requesty iPhone'a

Wniosek: Evil Twin jest łatwiejszy do wykrycia (jawny duplikat), ale skuteczniejszy w przełamaniu konkretnej ofiary.

KARMA jest trudniejsza do wykrycia (wygląda jak multi-SSID AP), ale mniej skuteczna na nowszych systemach (iOS/Android pasywne skanowanie).

An error occurred on this slide. Check the terminal for more information.

Mitygacja — jak sie chronic?

Dla administratorow sieci:

802.11w (PMF) — Protected Management Frames

Szyfruje ramki zarzadzania — blokuje ataki deauth.

WIDS/WIPS — systemy detekcji

Monitoruja duplikaty SSID i anomalie RSSI.

EAP-TLS — certyfikaty dla AP

Klient weryfikuje tozsamosc punktu dostepowego.

Regularne skanowanie eteru

W poszukiwaniu nieznanych AP — dokladnie to, co robi nasz `analize_pcap.py`.

Dla uzytkownikow:

VPN — szyfruje caly ruch

Nawet na rogue AP dane sa bezpieczne.

Unikanie otwartych sieci

Publiczne Wi-Fi to latwy cel.

Wylaczenie auto-join

Nie lacz sie automatycznie z "znanyymi" sieciami.

DNS-over-HTTPS

Chroni przed podslychem zapytan DNS.

Nasze narzedzia jako lekki WIDS:

`analize_pcap.py` + `beacon_diff.py` moga sluzyc jako podstawowy system detekcji — open source, Python, MIT license.

Podsumowanie

3

typy atakow
przeprowadzone

Evil Twin · KARMA · MANA

3

metody detekcji
zaimplementowane

IE · RSSI · Seq Numbers

55k+

pakietow
przechwyconych

10 cykli ON/OFF

Wszystkie ataki przeprowadzone i udokumentowane

Evil Twin — najskuteczniejszy, najłatwiejszy do wykrycia

KARMA — stealthowy, mniej skuteczny na nowych systemach

MANA — najbardziej zaawansowany technicznie

3 metody detekcji niezależnie potwierdzają obecność Evil Twin

WiFiSlayer uzupełnia nasze narzędzia o captive portal

Dziekujemy za uwage

Pytania?

github.com/Hose-Zur/BBSK-Evil-Twin

`analyze_pcap.py` · `beacon_diff.py` · `generate_report.py`